Incident analysis projects on brute force attack

Incident analysis - it is the process of investigating what happened, how it happened and how to prevent it from happening again.

Brute force analysis in windows

brute force attack is whereby an attacker attempting to gain unauthorized access by guessing multiple passwords on the user account.

Objective

To analyze login logs and identify signs of a brute force attack.

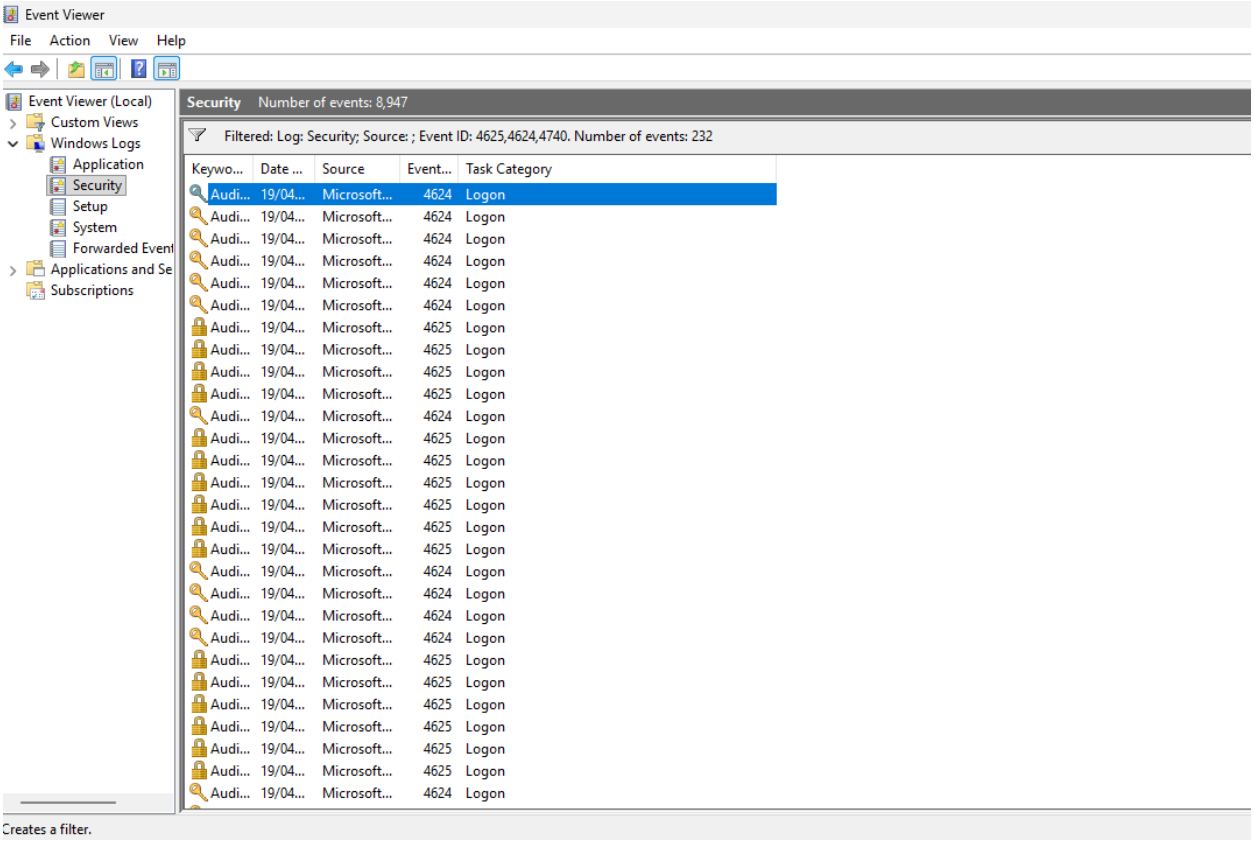
scenario

in this we shall try brute force attack on a windows machine and try to identify signs of brute force attack. I will put incorrect password multiple time then a correct password. Through this I will be able to demonstrated how to find brute force attack through analysing the security logs.

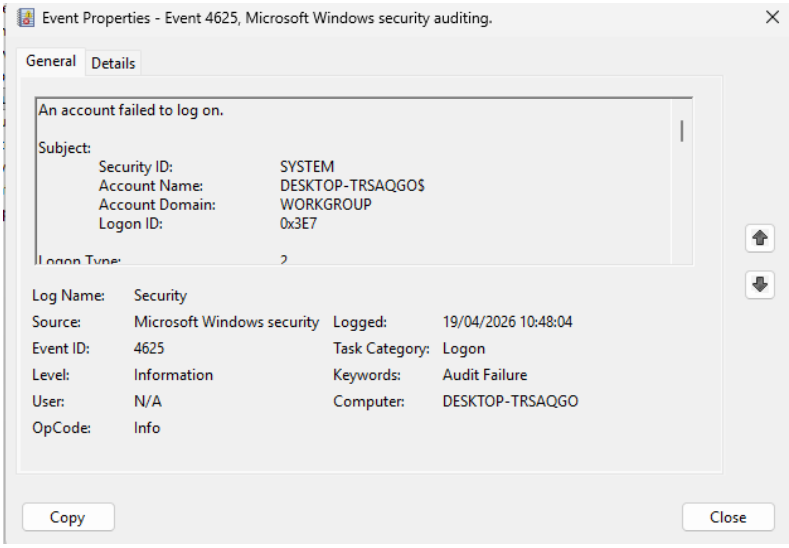
- In windows, logs are found in event viewer, in this we shall collect logs in security logs
- To identify failed login the event ID is 4625 and a successful login event ID is 4624

Event ID 4625-failed login attempt

Event ID 4624-successful login attempt



Event ID 4625-failed login attempt



An account failed to log on.

Subject:

Security ID: SYSTEM

Account Name: *DESKTOP-TRSAQGO$*

Account Domain: *WORKGROUP*

Logon ID: *0x3E7*

Logon Type: *2*

Account For Which Logon Failed:

Security ID: *NULL SID*

Account Name: *Caxtone*

Account Domain: *DESKTOP-TRSAQGO*

Failure Information:

Failure Reason: *Unknown user name or bad password.*

Status: *0xC000006D*

Sub Status: *0xC000006A*

Process Information:

Caller Process ID: *0x850*

Caller Process Name: *C:\Windows\System32\svchost.exe*

Network Information:

Workstation Name: *DESKTOP-TRSAQGO*

Source Network Address: *127.0.0.1*

Source Port: *0*

Detailed Authentication Information:

Logon Process: *User32*

Authentication Package: *Negotiate*

Transited Services: *-*

Package Name (NTLM only): *-*

Key Length: 0

This event is generated when a logon request fails. It is generated on the computer where access was attempted.

The Subject fields indicate the account on the local system which requested the logon. This is most commonly a service such as the Server service, or a local process such as Winlogon.exe or Services.exe.

The Logon Type field indicates the kind of logon that was requested. The most common types are 2 (interactive) and 3 (network).

The Process Information fields indicate which account and process on the system requested the logon.

The Network Information fields indicate where a remote logon request originated. Workstation name is not always available and may be left blank in some cases.

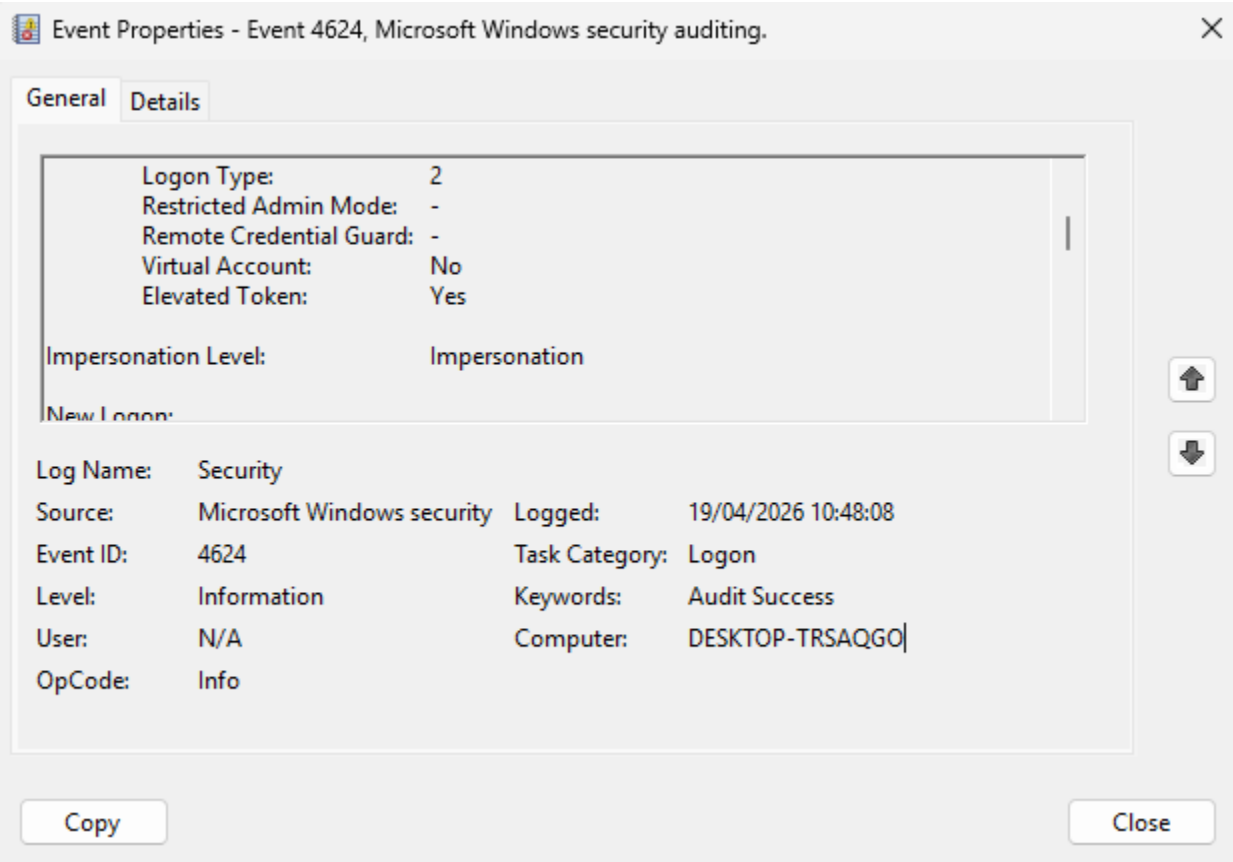
The authentication information fields provide detailed information about this specific logon request.

- Transited services indicate which intermediate services have participated in this logon request.

- Package name indicates which sub-protocol was used among the NTLM protocols.

- Key length indicates the length of the generated session key. This will be 0 if no session key was requested.

Event ID 4624-successful login attempt



An account was successfully logged on.

Subject:

Security ID: SYSTEM

Account Name: DESKTOP-TRSAQGO$

Account Domain: WORKGROUP

Logon ID: 0x3E7

Logon Information:

Logon Type: 2

Restricted Admin Mode: -

Remote Credential Guard: -

Virtual Account: No

Elevated Token: Yes

Impersonation Level: Impersonation

New Logon:

Security ID: DESKTOP-TRSAQGO\Caxtone

Account Name: Caxtone

Account Domain: DESKTOP-TRSAQGO

Logon ID: 0xD90187

Linked Logon ID: 0xD901D1

Network Account Name: -

Network Account Domain: -

Logon GUID: {00000000-0000-0000-0000-000000000000}

Process Information:

Process ID: 0x850

Process Name: C:\Windows\System32\svchost.exe

Network Information:

Workstation Name: DESKTOP-TRSAQGO

Source Network Address: 127.0.0.1

Source Port: 0

Detailed Authentication Information:

Logon Process: User32

Authentication Package: Negotiate

Transited Services: -

Package Name (NTLM only): -

Key Length: 0

This event is generated when a logon session is created. It is generated on the computer that was accessed.

The subject fields indicate the account on the local system which requested the logon. This is most commonly a service such as the Server service, or a local process such as Winlogon.exe or Services.exe.

The logon type field indicates the kind of logon that occurred. The most common types are 2 (interactive) and 3 (network).

The New Logon fields indicate the account for whom the new logon was created, i.e. the account that was logged on.

The network fields indicate where a remote logon request originated. Workstation name is not always available and may be left blank in some cases.

The impersonation level field indicates the extent to which a process in the logon session can impersonate.

The authentication information fields provide detailed information about this specific logon request.

- Logon GUID is a unique identifier that can be used to correlate this event with a KDC event.

- Transited services indicate which intermediate services have participated in this logon request.

- Package name indicates which sub-protocol was used among the NTLM protocols.

- Key length indicates the length of the generated session key. This will be 0 if no session key was requested.

Investigation of Failed login attempt

Observations

A failed login attempt event ID 4625 was detected targeting the account Caxtone

Key details

- Account name: Caxtone
- Source ip address: 127.0.0.1 -local machine
- Logon type: 2 -interactive
- Failure reason: Unknown user name or bad password.
- Elevated token indicates the user has admin privileges

Analysis

The failed login originated from the local system, indicating that the attempt was performed directly on the machine. This suggests either a user error or a controlled test scenario.

Conclusion

This event alone indicates a brute force attack because a repeated occurrences of similar events within a short timeframe could indicate a brute force attempt.

Recommendation

- Monitor for repeated failed login attempts
- Implement account lockout policies
- Enable multi-factor authentication (MFA)

Investigation of successful login attempt

Observations

A successful login attempt event ID 4625 was detected targeting the account Caxtone

Key details

- Multiple failed login attempts (Event ID 4625)
- Targeted account: Caxtone
- Source IP: 127.0.0.1 (local machine)
- Final successful login recorded (Event ID 4624)

Analysis

The repeated failed login attempts within a short time frame indicate a brute force attack attempt. The eventual successful login suggests that the correct credentials were eventually used.

Although the activity originated from the local machine, it simulates a real-world brute force attack scenario.

Indicators of Compromise (IOCs)

- Repeated failed login attempts
- Same account targeted
- Rapid succession of authentication failures

Conclusion

This activity is consistent with a brute force attack pattern. The system allowed multiple failed attempts before a successful login occurred.

Recommendations

- Implement account lockout policies
- Enable multi-factor authentication (MFA)
- Monitor login attempts for unusual patterns

- Restrict repeated login attempts

Skills Demonstrated

- Windows Event Log Analysis
- Threat Detection
- Incident Investigation

Logon type

In addition to what i have learnt is that there is something called logon type. Logon type helps a SOC analyst to know the type of attack. Example of type of logon

Logon type 2

-someone physically on the pc

Logon type 3

-possibly network attack

Example:

- Accessing shared folders
- Connecting to a server

Logon type 10

-this is a RDP attack